

Sistema de Controladoria Municipal — Plano de Desenvolvimento

Produto	Sistema de Controladoria Municipal
Empresa	HorizonAJ
Versão do plano	5
Data	02/10/2026
Situação	Aguardando aprovação

Resumo

Sistema web próprio, em Next.js com PostgreSQL, voltado à gestão pública e à Controladoria Municipal. As normas — Orientação Técnica 05 da Rede de Controle da Gestão Pública da Bahia e Resolução TCM-BA nº 1.120/2005 — são cadastradas como catálogos de dados, seguindo o modelo de dados do CISO Assistant. O controlador responde aos requisitos de cada norma (autoavaliação), o sistema identifica o que falta e monta o plano de ação.

Cada entidade é um cliente independente, com dados isolados: a Prefeitura é um cliente, a Câmara é outro e cada autarquia ou fundação é outro.

O sistema tem ainda:

- um único motor de planos de ação no formato 5W2H, compartilhado entre autoavaliação, auditorias, medidas e determinações do Tribunal de Contas;
- acesso "satélite" restrito, para quem recebe demandas da controladoria;
- IA da OpenAI focada na análise de documentos, sempre citando a origem de cada informação e com revisão humana obrigatória.

1. Tecnologia escolhida

Next.js (TypeScript) + PostgreSQL:

- **Uma única linguagem.** Telas e servidor em TypeScript, o que facilita manter com uma equipe pequena.
- **Melhor integração com a OpenAI.** O SDK oficial em TypeScript é de primeira linha.
- **Segurança forte no banco.** A segurança por linha do PostgreSQL (Row-Level Security) garante, dentro do próprio banco, que cada cliente só veja os próprios dados e que o usuário satélite só veja o que foi enviado a ele.

Camada	Escolha
Interface	Next.js, Tailwind, shadcn/ui e Recharts (gráficos)
Banco	PostgreSQL com Prisma e pgvector (busca semântica em documentos)
Autenticação	Auth.js
Arquivos	Armazenamento compatível com S3 (MinIO no servidor próprio)
Tarefas em segundo plano	Fila com Redis, para processar documentos e IA sem travar a tela
Relatórios PDF	HTML convertido em PDF (Playwright)
Infraestrutura	Docker Compose

2. O que aproveitar de cada repositório

- **CISO Assistant** é a base conceitual principal. Dele vem o modelo "norma → árvore de requisitos → autoavaliação → resposta por requisito → ação corretiva". Também vem a ideia de carregar normas como **arquivos versionados** (YAML), o que permite adicionar outros tribunais ou normas novas sem programar.
- **OpenBooks**: trilha de auditoria em que nada é apagado, só acrescentado, e fechamento de períodos (ciclo anual da autoavaliação).
- **OCA MIS Builder**: indicadores configuráveis por fórmula, usados nos painéis.
- **Empresa360**: organização do código em módulos por área. É só uma referência de arquitetura: como o repositório não tem licença, nada será copiado.
- **Metabase**: opcional numa fase posterior, para análises livres.

3. O que aproveitar do protótipo (só lógica e regras)

Não aproveito layout, cores, componentes nem código do protótipo. Aproveito apenas estas regras, revisadas e configuráveis:

- **Classificação de risco** por probabilidade (1 a 5) × impacto (1 a 5): 15 ou mais é crítico, de 10 a 14 é alto, de 6 a 9 é médio e abaixo de 6 é baixo. Vale para riscos e para a gravidade das Medidas.
- **Indicadores da LRF e mínimos constitucionais**, aplicados conforme o tipo de entidade:
 - despesa com pessoal (LRF, arts. 19 e 20), sempre com alerta em 90% do limite e limite prudencial em 95%:
 - **Prefeitura (Executivo): 54%** da Receita Corrente Líquida;
 - **Câmara (Legislativo): 6%** da Receita Corrente Líquida;
 - 60% é o limite do município como um todo, usado só como referência.

Correção em relação ao protótipo e às versões anteriores deste plano, que usavam 60% para o Executivo.

- Prefeitura: dívida consolidada (120% da Receita Corrente Líquida), operações de crédito (16%), garantias (22%), educação (mínimo de 25% dos impostos) e saúde (mínimo de 15%);
- Câmara: limite total de despesa do Legislativo por faixa de população (CF, art. 29-A) e folha de pagamento de no máximo 70% da receita da Câmara (CF, art. 29-A, §1º);
- autarquias e fundações: sem limites próprios da LRF (entram no cálculo do Executivo), com indicadores de execução orçamentária e financeira próprios.
- **Catálogo inicial de regras de verificação:** contrato vencendo em 30 dias, contrato sem fiscal (art. 117 da Lei 14.133/2021), aditivo acima de 25%, fracionamento de despesa, fornecedor no CEIS/CNEP (cadastros federais de empresas punidas), acúmulo de cargos, salário acima do teto, bem sem tombamento, consumo anormal de combustível e pagamento sem empenho.
- **Fracionamento:** soma das compras do mesmo objeto ao mesmo fornecedor num período, comparada ao limite de dispensa. Esse limite será um **parâmetro com vigência**, porque é atualizado anualmente por decreto.
- **Modelos de checklist:** licitação pela Lei 14.133/2021, contratos, folha, obras e convênios.
- **Listas de referência:**
 - tipos de auditoria;
 - situações das determinações do Tribunal de Contas (pendente, em andamento, vencida, concluída), com contagem de dias até o prazo;
 - tipos de manifestação da ouvidoria, com a opção de sigilo do manifestante.

4. Identidade visual (nova)

- A identidade visual do **Sistema de Controladoria Municipal** é criada do zero na fase 0: nome, logotipo, paleta, tipografia, componentes e modo escuro.
- A interface prioriza leitura de tabelas e formulários longos, que é o uso real do controlador.
- **Acessibilidade** seguindo o eMAG (Modelo de Acessibilidade em Governo Eletrônico) e o WCAG 2.1, nível AA.
- Antes de começar as telas, serão apresentadas duas ou três propostas de estilo para escolha.
- **A área do satélite é simplificada.** Quem a usa é eventual (secretários, diretores), então ela mostra só as demandas dele, o prazo e o botão de responder.

5. Organização e acesso

5.1 Estrutura

- **Cliente = entidade.** Cada entidade é um cliente independente da HorizonAJ, com a sua própria controladoria e os seus dados **totalmente isolados**. No mesmo município:
 - a Prefeitura é um cliente;
 - a Câmara Municipal é outro;
 - cada autarquia (por exemplo, o SAAE), fundação ou consórcio é outro.

- **Tipo de entidade.** Cada cliente tem um tipo: Prefeitura (Executivo), Câmara (Legislativo), Autarquia, Fundação ou Consórcio. O tipo define quais requisitos das normas e quais indicadores se aplicam. Por exemplo, os limites de pessoal são diferentes para Prefeitura e Câmara, e o art. 29-A da Constituição só se aplica à Câmara.
- **Município.** O município fica registrado como atributo do cliente. Serve para organizar a carteira da HorizonAJ, **sem compartilhar dados** entre as entidades do mesmo município.
- **Unidades.** Dentro de cada cliente, as unidades formam uma hierarquia (secretaria → departamento → setor, além de fundos como o Fundo Municipal de Saúde). Elas servem para **classificar e filtrar**, não para isolar dados. O controlador vê tudo do seu cliente e filtra por unidade quando quiser.
- **Avaliações separadas são opcionais.** Ao abrir um ciclo de autoavaliação ou uma auditoria, o controlador escolhe o alcance: a entidade inteira ou uma unidade.
- **Uma pessoa em mais de um cliente.** O mesmo usuário pode ter vínculo com mais de um cliente, por exemplo um controlador que atende a Prefeitura e uma autarquia. Ele troca de cliente dentro do sistema, e os dados nunca se misturam.

5.2 Perfis

Perfil	Acesso
Administrador HorizonAJ	Suporte da plataforma: cadastra clientes (entidades) e mantém os catálogos de normas
Controlador	Acesso total a todos os módulos e unidades do seu cliente
Equipe da controladoria (futuro)	Igual ao controlador, com permissões ajustáveis
Satélite	Acesso restrito: só as demandas enviadas a ele, com resposta e anexos, e o painel filtrado pela sua unidade

Os perfis valem por cliente. A mesma pessoa pode ser controladora num cliente e não ter acesso a outro.

5.3 Acesso satélite

Exemplo: o controlador da Prefeitura pede ao secretário de Saúde a lista de espera da regulação.

1. O controlador cria a demanda: assunto, descrição, documentos solicitados, prazo, destinatário (pessoa e unidade) e a origem, se houver (uma ação do plano, uma auditoria ou uma medida).
2. O secretário recebe um e-mail com link de acesso. No primeiro acesso, ele cria a senha; um código de verificação pode ser adicionado como segundo fator.
3. Ao entrar, ele vê **apenas** a sua caixa de demandas e o painel filtrado pela sua unidade.
4. Ele responde com texto e anexos. Também pode pedir prorrogação do prazo, com justificativa.
5. O controlador analisa a resposta e escolhe **aceitar e concluir** ou **devolver para complementação**.

Regras gerais da tramitação:

- O histórico é imutável e registra cada envio, visualização, resposta, devolução, prorrogação e conclusão, com data, hora e autor.

- Cada demanda passa pelas situações: enviada, visualizada, respondida, em análise, devolvida, concluída e vencida.
- O sistema envia lembretes automáticos antes do vencimento e avisa quando o prazo vence.
- Opcionalmente, a demanda gera um **ofício em PDF numerado**.
- **O que o painel do satélite mostra:** indicadores, ações, medidas e prazos que envolvem a unidade dele. Ele nunca vê detalhes de outras unidades nem informações internas da controladoria.

6. Módulos

6.1 Normas e requisitos (catálogo)

- As normas ficam em árvore com o texto literal: **norma** → **artigo** → **inciso** → **alínea**.
- Cada requisito tem: texto, tipo (estrutural, procedimental ou documental), **evidências esperadas**, periodicidade, peso, palavras-chave para a IA e **tipos de entidade a que se aplica**. Assim, uma Câmara não recebe requisitos exclusivos do Executivo, e vice-versa.
- **Primeiros catálogos:**
 - **Orientação Técnica 05/2024 da Rede de Controle da Gestão Pública da Bahia:** 8 condições, com os itens compostos divididos em requisitos verificáveis:
 - I: criação por lei, autonomia e quatro macrofunções, com subordinação direta à chefia do Poder;
 - II: pessoal concursado;
 - III: requisitos para a chefia;
 - IV: recursos materiais, tecnológicos e humanos;
 - V: estruturação das quatro macrofunções (auditoria interna, controle interno, corregedoria e ouvidoria);
 - VI: segregação de funções;
 - VII: capacitação contínua;
 - VIII: vedação de delegação a terceiros.
 - **Resolução TCM-BA nº 1.120/2005:** finalidades e atribuições (arts. 9 e 10), controle de pessoal (art. 11), objetos de acompanhamento (art. 12), apoio ao controle externo, responsabilidades e o Relatório Anual de Controle Interno (art. 17).
- Os requisitos que as duas normas têm em comum ficam ligados entre si. Assim, a mesma evidência pode atender aos dois.

6.2 Autoavaliação, análise do que falta e plano de ação

1. O controlador abre um ciclo ("Autoavaliação 2026"), escolhe as normas e o alcance: a entidade inteira ou uma unidade. O sistema já traz só os requisitos aplicáveis ao tipo da entidade.
2. Para cada requisito, marca **Atende, Atende parcialmente, Não atende ou Não se aplica**, escreve a justificativa e anexa evidências.
3. Se precisar de um documento de alguma área, **gera uma demanda satélite direto do requisito**. A resposta volta como evidência daquele requisito.

4. O sistema calcula a conformidade por norma, por capítulo e por macrofunção.
5. Com um clique, o sistema gera o **plano de ação** com uma ação para cada requisito não atendido ou parcialmente atendido.
6. Ao fim do ciclo, ele é fechado e congelado. O ciclo seguinte mostra a evolução em relação ao anterior.

6.3 Plano de ação: um único motor para todo o sistema

- Cada ação segue o formato **5W2H**: o quê, por quê, onde, quem, quando, como e quanto custa. Também tem prioridade, percentual de execução e marcos.
- A ação pode vir de quatro origens: **requisito**, **recomendação de auditoria**, **medida** ou **determinação do Tribunal de Contas**.
- **Quando o responsável é um satélite**, a ação chega na caixa de demandas dele. Ele atualiza o andamento e anexa as evidências, e o **controlador valida** a conclusão (ou devolve).
- O sistema envia alertas de prazo e mostra um painel de ações vencidas.

6.4 Auditorias

- **Plano Anual de Auditoria Interna**, com priorização por risco.
- **Ciclo de cada auditoria**: planejamento (escopo, matriz de planejamento e alcance: a entidade inteira ou uma unidade), execução com os modelos de checklist, **solicitações de auditoria** e registro de achados.
- As solicitações de auditoria usam o mesmo mecanismo das demandas satélite.
- Cada achado é registrado no padrão do TCU: **condição, critério, causa e efeito**. Cada recomendação vira uma ação no motor de planos de ação.
- Relatório preliminar e final em PDF. A manifestação do gestor auditado também chega a ele como demanda satélite.
- Os papéis de trabalho da auditoria são **visíveis só para a controladoria**.

6.5 Medidas (situações que precisam de intervenção, fora das normas)

- Registro de uma situação: descrição, origem (constatação, denúncia, alerta, análise da IA ou demanda externa), unidade envolvida e gravidade pela classificação de risco.
- Cada situação recebe um **plano de ação geral** no mesmo motor, e as ações podem ser enviadas aos envolvidos como demandas satélite.
- Painel próprio, separado da conformidade normativa.

6.6 IA para análise de documentos (OpenAI)

Processamento de cada documento enviado:

1. Extração do texto. PDFs escaneados passam por leitura de imagem do próprio modelo.
2. **Mascaramento de dados pessoais** antes de enviar à OpenAI, por causa da LGPD.
3. Divisão do texto em trechos, cálculo de embeddings e armazenamento no pgvector.

Funções:

1. **Documento comparado com a norma.** Por exemplo, a lei de criação da controladoria comparada com a Orientação Técnica 05: a IA sugere a resposta de cada requisito e cita o trecho e a página.
2. **Avaliação de evidência:** diz se o documento comprova o atendimento e o que falta.
3. **Análise da resposta do satélite:** verifica se o que foi enviado atende ao pedido, resume o conteúdo e destaca pontos de atenção.
4. **Análise de processos** (edital, contrato, termo de referência) pelos checklists, sugerindo achados.
5. **Perguntas sobre o acervo,** sempre com citação das fontes.
6. **Rascunhos de texto:** achados, plano de ação, texto de demandas e o Relatório Anual de Controle Interno do art. 17.

Regras fixas da IA:

- Toda sugestão fica como **"pendente de revisão"** até o controlador aceitar ou editar.
- Nenhuma afirmação sem citação do documento.
- Respostas em formato estruturado (JSON validado).
- A IA é usada **só pela controladoria**. O satélite não tem acesso a ela.
- Registro de quem pediu, qual documento foi enviado, qual modelo respondeu e o custo.

6.7 Relatórios

Relatório Anual de Controle Interno (art. 17), relatório da autoavaliação com plano de ação, relatório de auditoria, painel de medidas e relatório de demandas (atendidas, vencidas e tempo médio de resposta por unidade). Todos os relatórios podem ser filtrados por unidade e saem com o nome e o brasão da entidade.

6.8 Itens que atravessam o sistema

- Repositório de documentos com versões.
- Trilha de auditoria imutável.
- Notificações por e-mail e na própria tela.
- **Painel inicial com dados reais**, com filtro por unidade. Para o controlador, o filtro é livre dentro do seu cliente; para o satélite, fica travado na unidade dele.

7. Modelo de dados (principais tabelas)

- **Cliente e estrutura:**
 - **Cliente** : a entidade, com tipo (Prefeitura, Câmara, Autarquia, Fundação ou Consórcio), CNPJ, município, UF e brasão;
 - **Unidade** : em hierarquia, dentro de cada cliente;
 - **Usuario** ;
 - **VinculoCliente** : usuário + cliente + perfil, o que permite uma pessoa em mais de um cliente;
 - **EscopoSatelite** : as unidades que o satélite enxerga no painel.
- **Normas:** **Norma** (com versão), **Requisito** (árvore, com os tipos de entidade a que se aplica), **RequisitoCorrelato** .

- **Autoavaliação:** `CicloAvaliacao` (com alcance) e `RespostaRequisito`.
- **Planos de ação:** `PlanoAcao` (com a origem), `Acao`, `Marco` e `ValidacaoAcao`.
- **Demandas:** `Demanda` (com a origem: avulsa, requisito, ação, auditoria ou medida), `TramitacaoDemanda` (histórico imutável), `RespostaDemanda`, `PedidoProrrogacao` e `Oficio`.
- **Auditorias:** `PlanoAnualAuditoria`, `Auditoria`, `ModeloChecklist`, `ItemChecklist`, `Achado` e `Recomendacao`.
- **Medidas:** `Situacao`.
- **Determinações do Tribunal de Contas:** `DeterminacaoTC`.
- **Regras e parâmetros:** `RegraVerificacao` e `ParametroLegal` (valores com vigência e por tipo de entidade, como os limites de pessoal de 54% e 6%).
- **Documentos e IA:** `Documento`, `VersaoDocumento`, `TrechoDocumento` (com embedding), `AnaliseIA` e `SugestaoIA`.
- **Controle:** `LogAuditoria` (inclui os acessos do satélite) e `Notificacao`.

Segurança no banco: todas as tabelas de dados carregam o identificador do cliente (`cliente_id`), protegido pela segurança por linha do PostgreSQL. Na prática, a Câmara nunca enxerga dados da Prefeitura, e vice-versa, mesmo que haja um erro no código. Para o satélite há regras adicionais: ele só lê as demandas e ações enviadas a ele e os dados agregados da sua unidade.

8. Fases de entrega

Fase	Entrega
0. Fundação	Identidade visual nova, login, clientes por entidade com isolamento no banco, troca de cliente, unidades, perfis Controlador e Satélite, upload de documentos e trilha de auditoria
1. Núcleo	Catálogos da Orientação Técnica 05 e da Resolução 1120/2005, autoavaliação, motor de planos de ação, demandas e área do satélite e painel com filtros
2. Medidas e auditorias	Situações com plano de ação, Plano Anual de Auditoria, auditorias, checklists, solicitações de auditoria, achados e recomendações
3. IA	Processamento de documentos, comparação com a norma, avaliação de evidências, análise de respostas de satélites, análise de processos e rascunhos
4. Relatórios	PDFs (Relatório Anual de Controle Interno, auditoria, autoavaliação, demandas), ofícios e lembretes automáticos
5. Módulos complementares	Riscos, Monitor LRF, ouvidoria, determinações do Tribunal de Contas e motor de regras, usando as regras da seção 3

9. Pontos em aberto

1. **Clientes por entidade (definido).** Prefeitura, Câmara e cada autarquia ou fundação são clientes separados, com dados isolados entre si. Um painel que some entidades do mesmo município fica fora

do escopo atual; se for desejado no futuro, ele usaria apenas indicadores agregados e exigiria autorização das entidades envolvidas.

2. **Dados sensíveis nas respostas dos satélites.** Documentos como a lista de espera da regulação contêm dados de saúde, que a LGPD trata como sensíveis. Estão previstos acesso restrito, registro de cada visualização ou download e mascaramento antes de qualquer envio à IA.
3. **Texto oficial da Resolução 1120/2005.** Antes de cadastrar o catálogo, o texto literal será extraído da fonte oficial do TCM-BA, ou do PDF oficial ou lista de requisitos fornecidos pela HorizonAJ.
4. **Ambiente de desenvolvimento.** A instalação de dependências e a execução do projeto exigem autorização para rodar comandos fora do isolamento (sandbox) do terminal.

10. Próximos passos

1. Aprovação deste plano.
2. Fase 0: apresentação de duas ou três propostas de identidade visual para escolha.
3. Início da implementação das fases 0 e 1.

Referências

- [Orientação Técnica nº 05 — Rede de Controle da Gestão Pública da Bahia \(atualização de outubro de 2024\)](#)
- Resolução TCM-BA nº 1.120/2005: dispõe sobre a criação, a implementação e a manutenção de Sistemas de Controle Interno nos Poderes Executivo e Legislativo municipais.
- Constituição Federal, arts. 29-A, 31, 37 e 74; Lei Complementar nº 101/2000 (LRF), arts. 19, 20, 22 e 59; Lei nº 14.133/2021, arts. 7º, §2º, 117 e 169; Decreto nº 10.540/2020 (SIAFIC); Lei nº 13.709/2018 (LGPD).